Hack থেকে বাঁচো — Hack হলে Recover করো

সাধারণ মানুষ থেকে ছোট ব্যবসা — সবার জন্য সহজ ভাষায় সাইবার নিরাপত্তার সম্পূর্ণ গাইড। Technical জ্ঞান না থাকলেও বুঝবে।

📋 বিষয়সূচি

০১ **Threat Landscape — কে Attack করে ও কেন?**

Hacker-দের ধরন, Common attacks, তোমার risk কতটুকু

০২ **Website Security**

WordPress hardening, HTTPS, WAF, Security headers, Plugin security

০৩ **VPS/Server Security**

SSH hardening, Firewall, Fail2Ban, Auto-update, Non-root user

০৪ **Account ও Password Security**

Strong password, 2FA, Password manager, GitHub/cPanel সুরক্ষা

০৫ **Phishing ও Social Engineering থেকে বাঁচো**

Fake email চেনা, Malicious link, Domain spoofing

০৬ **নিজেই Security Audit করো**

Free tools দিয়ে vulnerability scan, Security score দেখো

০৭ **🚨 Hack হয়ে গেলে কী করবে?**

Hack-এর Signs, Emergency Response, Malware Remove, Recovery

০৮ **Backup Strategy — সেরা বিমা**

3-2-1 Rule, Automated backup, Restore test, Offsite backup

০৯ ✅ Interactive Security Checklist + Roadmap

Tick করো, progress দেখো, শেখার পথ

CHAPTER 01

🎯 Threat Landscape — কে Attack করে ও কেন?

শত্রু চিনলে আত্মরক্ষা সহজ হয়

কে তোমাকে Attack করে?

🤖 Automated Bots (৯০%)

বেশিরভাগ attack automated। Bot internet-এ সব website scan করে দুর্বলতা খোঁজে। তুমি "ছোট" হলেও exempt নও।

সবার জন্য ঝুঁকি

💰 Opportunistic Hackers

সুযোগ পেলেই attack করে — Spam পাঠানো, Crypto mining, Data চুরি করে বেচা। Target তুমি নও, target হলো সুযোগ।

সবচেয়ে সাধারণ

🏭 Ransomware Groups

ফাইল encrypt করে মুক্তিপণ চায়। ছোট ব্যবসা বড় target কারণ security কম থাকে।

আর্থিক ক্ষতি

🕵 Targeted Attack

প্রতিযোগী, প্রতিহিংসামূলক ব্যক্তি, বা APT group-এর নির্দিষ্ট attack। কম সাধারণ কিন্তু বেশি বিপজ্জনক।

নির্দিষ্ট লক্ষ্য

সবচেয়ে সাধারণ Attack পদ্ধতি

Attack	কীভাবে ঘটে	পরিণতি	মাত্রা
Brute Force	Password guess করা	Account takeover	HIGH
Phishing	Fake email/link	Credential চুরি	CRITICAL
Outdated Software	Unpatched vulnerability	Server compromise	CRITICAL
SQL Injection	Form-এ malicious input	Database চুরি	CRITICAL
Malicious Plugin	Fake/infected plugin install	Backdoor, malware	HIGH
Weak Password	Common password ব্যবহার	Full account access	CRITICAL
DDoS	Traffic flood করা	Website down	MEDIUM

💡 মূল কথা

৯০%+ attack prevent করা যায় শুধু basic security practices follow করে — Strong password, 2FA, Update রাখা, ভালো Backup। Advanced security-র দরকার নেই।

🎯 মনে রাখো

- ✅ "আমি ছোট, আমাকে কে attack করবে?" — এই ভুল ধারণা সবচেয়ে বিপজ্জনক
- ✅ বেশিরভাগ attack automated bot করে — তুমি target নও, তোমার vulnerability target
- ✅ Basic security = ৯০% সুরক্ষা

CHAPTER 02

Website Security

WordPress, cPanel, Shared Hosting — সব ধরনের website secure করো

WordPress Security — সবচেয়ে বেশি attacked platform

⚠ জানো কি?

সব website-এর ৪৩% WordPress দিয়ে তৈরি। তাই WordPress সবচেয়ে বেশি attack-এর target। কিন্তু সঠিকভাবে setup করলে অনেক নিরাপদ।

WordPress Hardening — ধাপে ধাপে

```
# ১. Default Admin Username বদলাও # "admin" username কখনো রাখবে না! # WP Admin → Users → নতুন user তৈরি করো → Administrator → পুরনো "admin" delete # ২. wp-config.php hardening # wp-config.php-তে যোগ করো: define('DISALLOW_FILE_EDIT', true); # Theme/Plugin editor বন্ধ define('DISALLOW_FILE_MODS', true); # Plugin/Theme install বন্ধ (optional) define('WP_DEBUG', false); # Production-এ debug বন্ধ define('FORCE_SSL_ADMIN', true); # Admin panel HTTPS-এ # ৩. .htaccess-এ protect করো: <Files wp-config.php> order allow,deny deny from all </Files> <Files .htaccess> order allow,deny deny from all </Files> # wp-login.php-তে IP restriction (optional): <Files wp-login.php> order deny,allow allow from YOUR.IP.ADDRESS deny from all </Files>
```

Essential Security Plugins

Wordfence

- Free WAF
- Malware scanner
- Brute force protection
- Login attempt block
- **Free**

🔐 Solid Security

- Two-factor auth
- Security hardening
- File change detection
- Database backup
- **Free**

💾 UpdraftPlus

- Automated backup
- Cloud storage (Drive, S3)
- One-click restore
- **Free**

HTTPS / SSL — অবশ্যই চালু করো

```
# Free SSL: Let's Encrypt (cPanel → SSL/TLS → Let's Encrypt) # অথবা Cloudflare Free SSL # .htaccess-এ HTTP → HTTPS redirect: RewriteEngine On RewriteCond %{HTTPS} off RewriteRule ^(.*)$ https://%{HTTP_HOST}%{REQUEST_URI} [L,R=301] # Nginx-এ: server { listen 80; server_name yourdomain.com; return 301 https://$server_name$request_uri; }
```

Security Headers — সহজ কিন্তু শক্তিশালী

```
# .htaccess-এ যোগ করো (Apache): Header always set X-Frame-Options "SAMEORIGIN"
Header always set X-XSS-Protection "1; mode=block" Header always set X-Content-
Type-Options "nosniff" Header always set Referrer-Policy "strict-origin-when-
cross-origin" Header always set Strict-Transport-Security "max-age=31536000;
includeSubDomains" Header always set Content-Security-Policy "default-src 'self'"
Header unset Server Header unset X-Powered-By # Check করো: securityheaders.com
```

Cloudflare — Free Protection Layer

✅ Cloudflare Free Plan-এ কী পাবে?

- 🛡️ DDoS protection (unlimited)
- 🔥 Web Application Firewall (WAF)
- 🚀 CDN (website দ্রুত হবে)
- 🔒 Free SSL certificate
- 🤖 Bot protection
- 🌐 Real IP hide (server IP attacker জানবে না)

Setup: cloudflare.com → Add site → DNS Nameserver change করো

🌐 Website Security মনে রাখো

- ✅ WordPress + Plugin + Theme সবসময় update রাখো
- ✅ HTTPS চালু করো — Let's Encrypt free
- ✅ Cloudflare → Free, সহজ, অনেক সুরক্ষা
- ✅ Plugin কম রাখো — যা দরকার না, delete করো

CHAPTER 03

VPS/Server Security

Linux server hardening — SSH থেকে Firewall পর্যন্ত

SSH Hardening — Remote Access নিরাপদ করো

```
# /etc/ssh/sshd_config পরিবর্তন করো: Port 2222 # Default 22 বদলাও (bot কম আসবে) PermitRootLogin no # Root login বন্ধ! PasswordAuthentication no # Password login বন্ধ → Key only PubkeyAuthentication yes # SSH Key ব্যবহার করো MaxAuthTries 3 # ৩ বারের বেশি try করতে পারবে না LoginGraceTime 20 # ২০ সেকেন্ডের মধ্যে login করতে হবে AllowUsers youruser # শুধু নির্দিষ্ট user Protocol 2 # SSH v2 only X11Forwarding no AllowTcpForwarding no # Restart করো: sudo systemctl restart sshd # SSH Key তৈরি (তোমার local machine-এ): ssh-keygen -t ed25519 -C "yourname@server" # Server-এ public key upload: ssh-copy-id -i ~/.ssh/id_ed25519.pub user@server
```

Firewall Setup — UFW (Ubuntu/Debian)

```
# UFW install ও enable: sudo apt install ufw sudo ufw default deny incoming # সব incoming block sudo ufw default allow outgoing # সব outgoing allow # প্রয়োজনীয় port খুলো: sudo ufw allow 2222/tcp # SSH (তোমার custom port) sudo ufw allow 80/tcp # HTTP sudo ufw allow 443/tcp # HTTPS # Enable করো: sudo ufw enable sudo ufw status verbose # নির্দিষ্ট IP থেকে SSH allow (সবচেয়ে নিরাপদ): sudo ufw allow from YOUR.IP.ADDRESS to any port 2222 # Rate limiting (Brute force রোধ): sudo ufw limit ssh # ৩০ সেকেন্ডে ৬ বারের বেশি try করলে block
```

Fail2Ban — Brute Force Auto-Block

```
# Install: sudo apt install fail2ban # /etc/fail2ban/jail.local তৈরি করো: [DEFAULT] bantime = 3600 # ১ ঘণ্টা ban findtime = 600 # ১০ মিনিটে maxretry = 3 # ৩ বারের বেশি fail → ban banaction = ufw [sshd] enabled = true port = 2222 # তোমার SSH port [wordpress] enabled = true port = http,https filter = wordpress logpath = /var/log/auth.log maxretry = 5 # Start করো: sudo systemctl enable fail2ban sudo systemctl start fail2ban sudo fail2ban-client status # Status দেখো sudo fail2ban-client status sshd # Banned IP দেখো
```

Auto Security Update

```
# Unattended Upgrades — Security patch auto install: sudo apt install unattended-upgrades sudo dpkg-reconfigure --priority=low unattended-upgrades # /etc/apt/apt.conf.d/50unattended-upgrades: Unattended-Upgrade::Allowed-Origins { "${distro_id}:${distro_codename}-security"; }; Unattended-Upgrade::AutoFixInterruptedDpkg "true"; Unattended-Upgrade::Remove-Unused-Dependencies "true"; Unattended-Upgrade::Automatic-Reboot "false"; # Manual update (নিয়মিত করো): sudo apt update && sudo apt upgrade -y
```

Non-Root User ও Sudo

```
# নতুন user তৈরি করো: sudo adduser yourname sudo usermod -aG sudo yourname # Sudo access দাও # Root login সম্পূর্ণ disable: sudo passwd -l root # Root password lock # Sudo log: sudo cat /var/log/auth.log | grep sudo # কে sudo ব্যবহার করেছে
```

🖥️ Server Security মনে রাখো

- ✅ SSH Port বদলাও + Key authentication + Root login বন্ধ
- ✅ UFW → শুধু দরকারি port খোলো
- ✅ Fail2Ban → Auto brute force protection

- ✅ Auto security update চালু রাখো

CHAPTER 04

🔐 Account ও Password Security

Strong password, 2FA, Password Manager — সবচেয়ে সহজ ও কার্যকর সুরক্ষা

Strong Password — সঠিক নিয়ম

❌ এই ধরনের Password কখনো না

- 123456, password, admin
- নিজের নাম, জন্ম তারিখ
- Company নাম + সংখ্যা
- সব জায়গায় একই password
- ৮ অক্ষরের কম

✅ এই নিয়ম follow করো

- কমপক্ষে ১৬ অক্ষর
- Uppercase + lowercase + number + symbol
- প্রতিটি account-এ আলাদা password
- Password Manager ব্যবহার করো
- Passphrase: `coffee-table-runs-42!`

Two-Factor Authentication (2FA) — সবচেয়ে গুরুত্বপূর্ণ

🔥 **2FA চালু করলে ৯৯.৯% Account Takeover বন্ধ হয়!**

Microsoft-এর গবেষণা: 2FA চালু থাকলে ৯৯.৯% automated attack কাজ করে না। এটা সবচেয়ে সহজ ও কার্যকর সুরক্ষা।

Platform	কীভাবে চালু করবে	Recommended App
Google/Gmail	myaccount.google.com → Security → 2FA	Google Authenticator
GitHub	Settings → Password & Auth → 2FA	Authy
cPanel/Hosting	Security → Two-Factor Auth	Google Authenticator
WordPress	Wordfence / Solid Security plugin	Authy
Facebook	Settings → Security → 2FA	Google Authenticator
Cloudflare	My Profile → Authentication → 2FA	Authy

Password Manager — Free ও Secure

🔑 Bitwarden

- Open source
- Cross-platform
- Free (unlimited)
- Self-host করা যায়

সেরা পছন্দ

🔑 KeePass

- Offline (local)
- Open source
- Windows, Linux

- Free

Offline পছন্দ

🔑 Proton Pass

- E2E encrypted
- Privacy-focused
- Free plan আছে
- Mobile app

Privacy

🔐 Account Security মনে রাখো

- ✅ 2FA → আজই চালু করো — সবচেয়ে গুরুত্বপূর্ণ পদক্ষেপ
- ✅ Bitwarden → সব password manage করো
- ✅ প্রতিটি account-এ আলাদা password — এটা না মানলে সব ঝুঁকিতে
- ✅ Recovery code/backup code সেভ করো — Print করে রাখো

CHAPTER 05

Phishing ও Social Engineering থেকে বাঁচো

Fake email, SMS, Link চেনার উপায়

Phishing Email চেনার উপায়

```
⚠ Suspicious Email Analysis:

From: "Google Security" <security@g00gle-alerts.com>   ← Domain ভুল!
To: you@email.com
Subject: URGENT: Your account will be suspended in 24 hours!  ← Urgency!

Dear Customer,                ← নাম নেই → Suspicious
Your Google account has been compromised.
Click here to verify: http://google-verify-now.xyz/login  ← Fake URL!

                              ✓ Real Google email হবে @google.com থেকে
                              ✓ Real URL হবে accounts.google.com
                              ✓ তোমার নাম থাকবে
```

Red Flags — এগুলো দেখলে সতর্ক হও

লক্ষণ	উদাহরণ	কী করবে
Urgent/Emergency ভাষা	"24 hours to act!", "Account suspended"	থামো, যাচাই করো
Suspicious Sender	paypa1.com, g00gle.com	Domain দেখো সতর্কভাবে
Generic Greeting	"Dear Customer", "Dear User"	Legit company নাম জানে

লক্ষণ	উদাহরণ	কী করবে
Suspicious Link	bit.ly/xyz, random-domain.com	Hover করে URL দেখো
Unexpected Attachment	.exe, .zip, .docm, invoice.pdf.exe	খুলবে না!
Password চাওয়া	"Enter your password to verify"	কোনো company password চায় না

Link Check করার পদ্ধতি

```
# Click করার আগে এই tools দিয়ে check করো: # VirusTotal — URL/File scan: https://www.virustotal.com/gui/home/url # URLVoid — Reputation check: https://www.urlvoid.com # Google Safe Browsing: https://transparencyreport.google.com/safe-browsing/search # Shortened URL expand করো: https://unshorten.it https://expandurl.net # বা Browser-এ hover করো → Bottom-এ URL দেখাবে # Mobile-এ Long press → URL preview দেখো
```

Email Security Setup

```
# তোমার domain-এ SPF, DKIM, DMARC set করো # এগুলো না থাকলে তোমার domain থেকে fake email পাঠানো সহজ # DNS Records যোগ করো (cPanel → DNS Zone Editor): # SPF Record (কে email পাঠাতে পারবে): TXT @ "v=spf1 include:_spf.google.com ~all" # DMARC Record (Fake email কী করবে): TXT _dmarc "v=DMARC1; p=quarantine; rua=mailto:dmarc@yourdomain.com" # Check করো: https://mxtoolbox.com/spf.aspx https://dmarcian.com/dmarc-inspector/
```

📧 Phishing মনে রাখো

- ✅ Urgent email এলে → থামো, সরাসরি website-এ গিয়ে check করো
- ✅ Sender domain সতর্কভাবে দেখো — g00gle.com ≠ google.com
- ✅ Link click-এর আগে → VirusTotal-এ check করো

- ✅ SPF + DMARC → তোমার domain থেকে fake email বন্ধ

CHAPTER 06

🔍 নিজেই Security Audit করো

Free tools দিয়ে নিজের website ও server-এর দুর্বলতা খুঁজে বের করো

Free Online Tools

🔒

SSL Labs

SSL/TLS configuration grade দেখো

ssllabs.com/ssltest

🛡️

Security Headers

HTTP security header check

securityheaders.com

🔍

Mozilla Observatory

Website security score A-F

observatory.mozilla.org

🦠

VirusTotal

URL ও File scan করো

virustotal.com

MXToolbox

SPF, DKIM, DMARC check

mxtoolbox.com

HaveIBeenPwned

Email data breach-এ আছে কিনা

haveibeenpwned.com

Shodan

তোমার server কী expose করছে

shodan.io

WPScan

WordPress vulnerability check

wpscan.com (free API)

Qualys FreeScan

Full vulnerability scan

freescan.qualys.com

Server-এ Command দিয়ে Audit

```
# Open ports দেখো: sudo ss -tulnp # কোন port open? sudo netstat -tulnp # Alternative # শুধু দরকারি port খোলা থাকা উচিত (22/2222, 80, 443) # Failed login attempt: sudo grep "Failed password" /var/log/auth.log | tail -20 sudo grep "Invalid user" /var/log/auth.log | tail -20 sudo lastb | head -20 # Failed login list # Running services: sudo systemctl list-units --type=service --state=running # SUID files (Privilege escalation risk): find / -perm -4000 -type f 2>/dev/null | head -20 # World-writable files: find / -xdev -perm -0002 -type f 2>/dev/null | grep -v proc # Lynis — Comprehensive security audit: sudo apt install lynis sudo lynis audit system # Score ও recommendations দেখাবে
```

Data Breach Check

```
# HaveIBeenPwned API দিয়ে email check: curl "https://haveibeenpwned.com/api/v3/breachedaccount/your@email.com" \ -H "hibp-api-key: YOUR_KEY" # CLI Tool: pip3 install h8mail h8mail -t your@email.com # Email breach check # Password কোনো breach-এ আছে কিনা (SHA1 hash দিয়ে, password safe): # https://haveibeenpwned.com/Passwords # k-anonymity model ব্যবহার করে — password কখনো পাঠায় না
```

🔍 Security Audit মনে রাখো

- ✅ মাসে একবার: SSL Labs + SecurityHeaders + Observatory check করো
- ✅ HaveIBeenPwned → তোমার email breach-এ গেছে কিনা দেখো
- ✅ Lynis → Server-এ comprehensive audit

- ✅ Failed login check → নিয়মিত auth.log দেখো

CHAPTER 07

🚨 Hack হয়ে গেলে কী করবে?

Emergency Response — ধীরে না, দ্রুত action নাও

Hack-এর Signs — কীভাবে বুঝবে?

🚨 Website Hacked Signs

- Website অন্য site-এ redirect হচ্ছে
- Unknown page/content দেখাচ্ছে
- Google "This site may harm your computer" দেখাচ্ছে
- Google Search Console-এ Security issue
- Hosting থেকে suspension notice
- Admin panel-এ অচেনা user
- অস্বাভাবিক traffic spike

🚨 Account/Server Hacked Signs

- Login করতে পারছো না
- অচেনা email/message পাঠানো হয়েছে
- Password change notification
- Account-এ অচেনা activity
- Server-এ unknown process চলছে
- CPU/Memory অস্বাভাবিক বেশি
- অচেনা cron job আছে

🚨 Emergency Response — এই ক্রমে করো!

1 **🔌 সাথে সাথে Isolate করো**

Server-এর network connection বন্ধ করো অথবা Maintenance Mode চালু করো। Website offline করো যাতে visitor-রা ক্ষতিগ্রস্ত না হয়।

```
# WordPress Maintenance Mode: echo '<?php $upgrading = time(); ?>' > .maintenance # অথবা Cloudflare → Under Attack Mode চালু করো
```

2 **🔑 সব Password পরিবর্তন করো**

cPanel, WordPress Admin, Database, FTP, Email, Hosting account — সব কিছুর password বদলাও। অন্য device থেকে করো।

3 **📸 Evidence সংরক্ষণ করো**

Log file, screenshot সেভ করো। কী হয়েছে তা বোঝার জন্য ও Legal প্রয়োজনে কাজে লাগবে।

```
sudo cp /var/log/auth.log /backup/auth_$(date +%Y%m%d).log sudo cp /var/log/apache2/access.log /backup/access_$(date +%Y%m%d).log
```

4 **🔍 Malware Scan করো**

```
# WordPress Malware Scanner (Wordfence): # Wordfence → Scan → Start New Scan # Server-এ ClamAV দিয়ে: sudo apt install clamav sudo freshclam # Update definitions sudo clamscan -r /var/www/ --infected --log=scan_result.txt # Malicious file খোঁজো: find /var/www -name "*.php" -newer /var/www/index.php -ls find /var/www -name "*.php" | xargs grep -l "eval(base64_decode" find /var/www -name "*.php" | xargs grep -l "system\|exec\|passthru"
```

5 **🧹 Malware Remove করো**

Infected file delete বা clean করো। WordPress-এর ক্ষেত্রে core files reinstall করা সবচেয়ে নিরাপদ।

```
# WordPress core reinstall: wp core download --force # WP-CLI দিয়ে wp plugin update --all wp theme update --all # Backdoor চেক করো: grep -r "eval(" /var/www/ --include="*.php" -l grep -r "base64_decode" /var/www/ --include="*.php" -l grep -r "shell_exec\|system\|passthru" /var/www/ --include="*.php" -l
```

6 🔄 **Clean Backup থেকে Restore করো**

Hack-এর আগের clean backup থেকে restore করা সবচেয়ে নিরাপদ। কিন্তু নিশ্চিত হও সেই backup-ও clean।

7 🔒 **দুর্বলতা Fix করো**

কীভাবে hack হলো সেটা বুঝে সেই দুর্বলতা ঠিক করো। না হলে আবার hack হবে!

8 ✅ **Google Blacklist থেকে বের হও**

Google-এ flag হলে: Search Console → Security Issues → Review requested। Malware clean করার পরে request করো।

🚨 Hack Recovery মনে রাখো

- ✅ Hack হলে panic নয় — systematically এগোও
- ✅ অন্য device থেকে password change করো
- ✅ Backup না থাকলে অনেক কঠিন হয় → এখনই backup setup করো
- ✅ শুধু malware মুছলেই হবে না — vulnerability ঠিক করতে হবে

CHAPTER 08

💾 Backup Strategy — সেরা বিমা

Backup না থাকলে সব হারানোর ঝুঁকি — 3-2-1 Rule follow করো

3-2-1 Backup Rule

```
3-2-1 Backup Rule:

3 copies of data     → Original + 2 backups
2 different media    → Server + External drive বা Cloud
1 offsite location   → Google Drive / S3 / Different datacenter

Example:
Production Server  →  Local Backup (same server)  →  Google Drive
     (live)              (daily)                     (weekly, offsite)
                                                          ↑
                                                   এটা সবচেয়ে গুরুত্বপূর্ণ!
⚠️  Server-এ শুধু backup রাখলে → Server নষ্ট হলে backup-ও যাবে!
```

WordPress Automated Backup

```
# UpdraftPlus Plugin (Free): # Install করো → Settings → Backup Schedule: # Files: Daily backup → Google Drive-এ # Database: Daily backup → Google Drive-এ # Retain: 14 days # Manual backup (cPanel): # cPanel → Backup Wizard → Full Backup → Download # WP-CLI দিয়ে automated backup: # Cron job: প্রতিদিন রাত ২টায়: 0 2 * * * cd /var/www/html && wp db export /backup/db_$(date +\%Y\%m\%d).sql 0 3 * * * tar -czf /backup/files_$(date +\%Y\%m\%d).tar.gz /var/www/html/wp-content/
```

Server Automated Backup — rsync + cron

```
# Daily backup script: /usr/local/bin/backup.sh #!/bin/bash DATE=$(date +%Y%m%d) BACKUP_DIR="/backup/$DATE" mkdir -p $BACKUP_DIR # Database backup mysqldump -u root -p'password' --all-databases > $BACKUP_DIR/databases.sql # Website files tar -czf $BACKUP_DIR/www_files.tar.gz /var/www/html/ # Config files cp -r /etc/nginx/ $BACKUP_DIR/nginx_config/ cp /etc/crontab $BACKUP_DIR/crontab_backup # 30 দিনের বেশি পুরনো backup মুছো: find /backup/ -mtime +30 -delete echo "Backup completed: $DATE" # Cron job (sudo crontab -e): 0 2 * * * /usr/local/bin/backup.sh >> /var/log/backup.log 2>&1 # Offsite backup (Google Drive) — rclone: sudo apt install rclone rclone config # Google Drive configure করো rclone sync /backup gdrive:backup/ # Sync করো # Cron-এ যোগ করো: 30 3 * * * rclone sync /backup gdrive:backup/ --log-file=/var/log/rclone.log
```

Backup Test — সবচেয়ে গুরুত্বপূর্ণ ধাপ

⚠️ **Untested Backup = No Backup!**

প্রতি মাসে একবার backup restore করে দেখো এটা কাজ করছে কিনা। অনেকে মনে করে backup আছে, কিন্তু জরুরি সময়ে দেখা যায় backup corrupt বা incomplete।

```
# WordPress backup test (Staging site-এ): # UpdraftPlus → Existing Backups → Restore (staging-এ করো, live-এ না) # Database restore test: mysql -u root -p test_database < backup_database.sql # File restore test: tar -xzf backup_files.tar.gz -C /tmp/restore_test/ ls /tmp/restore_test/ # File আছে কিনা দেখো
```

💾 Backup মনে রাখো

- ✅ 3-2-1 Rule: ৩ কপি, ২ media, ১ offsite
- ✅ Daily automated backup + Cloud storage
- ✅ মাসে একবার restore test করো

- ✅ আজই শুরু করো — hack-এর পরে দেরি হয়ে যাবে

CHAPTER 09

✅ Interactive Security Checklist

Tick করো, progress দেখো — তোমার security কতটুকু শক্তিশালী?

0 / 40 সম্পন্ন

🔐 Account ও Password Security

- [ ] **2FA চালু করো** — Google, GitHub, cPanel, hosting সব account-এ
- [ ] **Password Manager** — Bitwarden install করো
- [ ] সব গুরুত্বপূর্ণ account-এ আলাদা strong password দাও (১৬+ অক্ষর)
- [ ] HaveIBeenPwned-এ email check করো
- [ ] 2FA Recovery code print করে নিরাপদ জায়গায় রাখো

🌐 Website Security

- [ ] **HTTPS চালু করো** — Let's Encrypt (Free SSL)
- [ ] **Cloudflare** — Free plan setup করো
- [ ] WordPress + সব Plugin + Theme update করো
- [ ] WordPress Admin username "admin" বদলাও
- [ ] Wordfence install ও configure করো

- [ ] Security Headers যোগ করো (.htaccess)
- [ ] Unused plugin ও theme delete করো
- [ ] securityheaders.com — grade A বা B পাচ্ছো?

🖥️ Server Security (VPS থাকলে)

- [ ] SSH Port বদলাও (22 থেকে অন্য port)
- [ ] SSH Key authentication + Password login বন্ধ
- [ ] Root login বন্ধ করো (`PermitRootLogin no`)
- [ ] UFW Firewall চালু করো — শুধু দরকারি port খোলো
- [ ] Fail2Ban install ও configure করো
- [ ] Auto security update চালু করো
- [ ] Non-root user তৈরি করো ও sudo দাও

📧 Email ও Phishing Security

- [ ] SPF Record DNS-এ যোগ করো
- [ ] DMARC Record DNS-এ যোগ করো
- [ ] Suspicious link → VirusTotal-এ check করার অভ্যাস করো
- [ ] Team/Staff-কে Phishing চেনার training দাও

💾 Backup Strategy

- [ ] Daily automated backup চালু করো (UpdraftPlus বা cron)
- [ ] Cloud-এ backup যাচ্ছে? (Google Drive / S3)
- [ ] Backup restore test করো — আসলেই কাজ করছে?
- [ ] কমপক্ষে ১৪ দিনের backup retention রাখো

👁 Monitoring ও Audit

- [ ] Google Search Console-এ website add করো (Security alerts পাবে)
- [ ] SSL Labs — grade A+ পাওয়ার চেষ্টা করো
- [ ] Uptime monitor চালু করো — uptime.kuma.pet (Self-hosted) বা uptimerobot.com (Free)
- [ ] মাসে একবার failed login ও server log দেখো

🚨 Incident Response Prep

- [ ] Hosting support contact number/chat জানো
- [ ] Domain registrar login credentials ready রাখো
- [ ] Hack হলে কী করবে তার plan তৈরি করো (Chapter 7 print করো)

⚡ Advanced (Optional কিন্তু ভালো)

- [ ] Lynis — Server-এ security audit চালাও

- [ ] WPScan — WordPress vulnerability check করো
- [ ] Shodan — তোমার server কী publicly expose করছে দেখো
- [ ] File integrity monitoring চালু করো (Tripwire বা AIDE)
- [ ] নিজে বা team একটি Phishing simulation করো

⚡ Quick Reference Cheat Sheet

🔍 Security Check Tools

`ssllabs.com/ssltest`	SSL grade
`securityheaders.com`	Headers check
`observatory.mozilla.org`	Security score
`haveibeenpwned.com`	Breach check
`virustotal.com`	URL/file scan
`mxtoolbox.com`	SPF/DMARC

🚨 Hack হলে তাৎক্ষণিক

`1. Isolate`	Site offline করো
`2. Change passwords`	সব password বদলাও
`3. Save logs`	Evidence রাখো
`4. Scan + Clean`	Malware remove
`5. Restore backup`	Clean backup থেকে
`6. Fix vulnerability`	দুর্বলতা ঠিক করো

🖥️ Server Commands

`sudo ufw status`	Firewall status
`sudo fail2ban-client status`	Banned IPs
`sudo lastb | head -20`	Failed logins
`sudo lynis audit system`	Security audit
`sudo clamscan -r /var/www/`	Malware scan
`sudo ss -tulnp`	Open ports

💾 Backup Commands

`mysqldump -u root -p db > backup.sql`	DB backup
`tar -czf backup.tar.gz /var/www/`	Files backup
`rclone sync /backup gdrive:backup/`	Cloud sync
`wp db export backup.sql`	WP-CLI DB
`mysql -u root -p db < backup.sql`	Restore DB

🗺️ Security Improvement Roadmap

1

🔥 Phase 1 — আজই করো (১ ঘণ্টা)

এগুলো না করলে সবচেয়ে বেশি ঝুঁকিতে আছো।

2FA চালু · Password update · Backup setup · WP Update

↓

2

⚡ Phase 2 — এই সপ্তাহে (৪-৫ ঘণ্টা)

Core security setup সম্পন্ন করো।

Cloudflare setup · HTTPS/SSL · Wordfence · SSH hardening · UFW + Fail2Ban

↓

3

🛡️ Phase 3 — এই মাসে

Advanced protection যোগ করো।

Security Headers | SPF/DMARC | Security Audit | Uptime Monitor | Backup test

↓

4

✅ Phase 4 — নিয়মিত Maintenance

Security একবার করে ছেড়ে দেওয়ার জিনিস নয় — নিয়মিত রক্ষণাবেক্ষণ দরকার।

সাপ্তাহিক: Update | মাসিক: Audit | মাসিক: Backup test | মাসিক: Log review

🛡 "Security একটি journey, destination নয় — প্রতিদিন একটু উন্নত করো।"

এই গাইড সম্পূর্ণ শিক্ষামূলক উদ্দেশ্যে। নিজের ও authorized system-এ apply করো।

v1.0 — Website & System Security Guide | Interactive Checklist | Bilingual | Dark/Light Mode